Phase 20: Comprehensive Risk Analysis & Risk Register

Document Code: RR-DOC-001

Project: Duplicate Bin Ecosystem

Standard: ISO 31000 Risk Management Framework

Classification: IDENTIFIED FROM PROJECT | BA-RECOMMENDED RISK

1. Risk Evaluation Matrix

```
        PROBABILITY
HIGH    |  [Medium Risk]       [HIGH RISK]           [CRITICAL RISK]
        |  R-04 (i18n Gaps)    R-03 (Cloud Reluctance) R-01 (Path Traversal)
MED     |  [Low Risk]          [MEDIUM RISK]         [HIGH RISK]
        |  R-05 (ReDoS Regex)  R-07 (DB Concurrency) R-02 (OS Directory Wipe)
LOW     |  [Trivial Risk]      [Low Risk]            [MEDIUM RISK]
        |                      R-06 (Credit Double)  R-08 (Memory OOM)
        └──────────────────────────────────────────────────────────────
           LOW IMPACT          MEDIUM IMPACT         HIGH IMPACT
```

2. Risk Register

Part A: Risks Identified Directly from Project Code & Documentation

Risk ID	Risk Description	Root Cause	Impact	Probability	Severity	Mitigation Strategy Implemented in Project	Owner	Status
R-01	**Path Traversal & Symlink**	Malicious or circular symbolic	High (Arbitrary file tamperi	Low	**HIGH**	`_safe_archive_path()` resolves canonica	Lead Architect	**MITIGATED**

	Symlink	symbolic	tamperi			canonica		

Phase 20: Comprehensive Risk Analysis & Risk Register

Risk ID	Risk Description	Root Cause	Impact	Probability	Severity	Mitigation Strategy Implemented in Project	Owner	Status
	Arbitrary File Deletion	links pointing outside target scan directory.	ng or deletion).			l paths using `os.path.realpath` and verifies sandbox boundary confinement.		
R-02	**Accidental Wiping of Critical OS System Files**	User selects `C:\Windows`, `C:\Program Files`, or `/etc` as the scan directory.	Critical (Operating system boot failure and crash).	Low	**CRITICAL**	Hardcoded blacklist in `duplicate_bin/core/utils.py` (`UNSAFE_DIRS`) halts scanning immediately if an OS root	Core Dev Lead	**MITIGATED**

						OS root		

Phase 20: Comprehensive Risk Analysis & Risk Register

Risk ID	Risk Description	Root Cause	Impact	Probability	Severity	Mitigation Strategy Implemented in Project	Owner	Status
						is targeted.		
R-03	**Enterprise Reluctance to Adopt Cloud Relay**	Corporate IT security fears corporate data or file contents are exfiltrated to the SaaS server.	High (Enterprise sales friction and lost adoption).	High	**HIGH**	Architectural design ensures file contents never leave local client machine. Only metadata and aggregate byte counts flow to cloud.	Product Owner	**MANAGED**
R-04	**Internationalization**	UI language	Medium (Customer	High	**MEDIUM**	Centralized `TranslationMan`	Frontend Dev	**OPEN**

	ion	e	er			`tionMan`		

Phase 20: Comprehensive Risk Analysis & Risk Register

Risk ID	Risk Description	Root Cause	Impact	Probability	Severity	Mitigation Strategy Implemented in Project	Owner	Status
	(i18n) String Gaps	selector exists, but secondary popups and error dialogs remain hardcoded in English.	confusion in non-English markets; QA bug reports).			`ager` instantiated; full internationalization string extraction scheduled for v0.3.0.		
R-05	**Regular Expression Denial of Service (ReDoS)**	User enters a catastrophic backtracking regex pattern in the pre-scan filter dialog.	Medium (GUI thread freeze or 100% CPU lockup).	Low	**MEDIUM**	Strict 512-character limit on input pattern string; regex compilation wrapped in executio	Security Auditor	**MITIGATED**

						executio		

Risk ID	Risk Description	Root Cause	Impact	Probability	Severity	Mitigation Strategy Implemented in Project	Owner	Status
						n timeout handler.		
R-06	**Duplicate Credit Deduction on Telemetry Retries**	Network latency causes desktop agent to re-send telemetry payload for a completed scan.	High (Customer double-billed for credit bytes).	Medium	**HIGH**	Idempotency guard in `backend/app/main.py#L165`: credits are debited **only once** upon initial state transition to `completed`.	Backend Dev	**MITIGATED**

Part B: BA-Recommended Risks (Anticipated Enterprise & Operational Risks)

Risk ID	Risk Description	Root Cause	Impact	Probability	Severity	BA-Recommended Mitigation Plan	Recommended Owner	Status
R-07	**SQLite Hash Cache Corruption under Extreme Threading**	Abrupt power loss or simultaneous worker thread write collisions during cache updates.	Medium (Corrupted cache database, forcing full re-scan).	Low	**MEDIUM**	Mandate SQLite Write-Ahead Logging (WAL) mode (`PRAGMA journal_mode=WAL`) and wrap cache writes in retry backoff loops.	Tech Lead	**RECOMMENDED**
R-08	**Memory Exhaustion (OOM) on Multi-Terabyte Video Reposit**	Caching hundreds of thousands of video metadata objects in	High (Process terminated by OS Out-Of-Memory killer).	Medium	**HIGH**	Enforce bounded LRU memory caches (already implemented for thumbnails) and	Tech Lead	**RECOMMENDED**

	Reposit	in				ails) and		

Risk ID	Risk Description	Root Cause	Impact	Probability	Severity	BA-Recommended Mitigation Plan	Recommended Owner	Status
	ories	memory.				stream file metadata to SQLite in batches of 5,000.		
R-09	**Corporate Cloud Storage Rate Limiting**	Future cloud connectors (Google Drive / OneDrive) trigger API throttling during high-volume scans.	High (Scan failures or temporary API bans).	High	**HIGH**	Implement exponential backoff retry policies and request rate-limiting headers in cloud connector architecture.	Integration Lead	**ROADMAP**
R-10	**Quarantine**	Archiving large	High (System	Medium	**HIGH**	Check available	BA / Dev Lead	**RECOMMENDE**

	ine	g large	(System			available		**MENDE**

Phase 20: Comprehensive Risk Analysis & Risk Register

Risk ID	Risk Description	Root Cause	Impact	Probability	Severity	BA-Recommended Mitigation Plan	Recommended Owner	Status
	Storage Exhaustion	multi-gigabyte video files exhausts remaining disk space on the drive hosting `~/.duplicate_bin/`.	write failure during quarantine).			free disk space on quarantine partition prior to file move; block archiving if available space is $< 1.1\times$ target batch size.		**D**